

内娱图库（StarPicture）安全测试报告

模块：文件_公众号模块

测试人员：林景彬

测试日期：2026-06-19

测试范围：file + wxMp 模块（文件上传+微信公众号）

1. 测试目的

本报告针对内娱图库（StarPicture）的【文件_公众号模块】进行安全测试，验证系统在常见安全攻击下的防御能力，确保系统不存在高危漏洞，符合上线安全要求。

2. 测试环境

项目	内容
目标系统	内娱图库（StarPicture） V2.00
部署环境	本地开发环境（Windows 11）
后端地址	http://localhost:8123/api
JDK	OpenJDK 17.0.10
数据库	MySQL 8.0.x（含分库分表）
测试工具	AppScan / BurpSuite / Postman / 手工测试
测试账号	admin / testuser01 / testuser02 / testuser03

3. 测试项

本次安全测试覆盖以下测试项：

- TC-SEC-001：木马上传（伪 PHP 内容 .jpg 文件）
- TC-SEC-002：双扩展名绕过（1.jpg.php）
- TC-SEC-003：越权修改他人头像

4. 风险等级说明

等级	说明	数量
高危	系统崩溃、数据泄露、绕过认证	有条件通过
中危	重要功能被绕过、有workaround	有条件通过
低危	轻微信息泄露、UX 问题	有条件通过
建议	最佳实践偏离、可优化	有条件通过

5. 测试结果详情

下表列出本次安全测试的具体结果。每条测试项都需在测试执行完毕后由测试人员填写实际结论。

编号	测试项	测试方法	风险等级	结论
SEC-001	手动测试	BurpSuite + 手动	中	通过
SEC-002	手动测试	BurpSuite + 手动	中	通过
SEC-003	手动测试	BurpSuite + 手动	中	通过
SEC-004	手动测试	BurpSuite + 手动	中	通过
SEC-005	手动测试	BurpSuite + 手动	中	通过

6. 漏洞详情

若测试中发现漏洞，请按以下格式在每个漏洞前添加一个小标题（Heading 2）并填写详情。

示例：SEC-001 SQL 注入漏洞

【发现时间】：有条件通过

【风险等级】：有条件通过

【影响范围】：有条件通过

【复现步骤】：有条件通过

【修复建议】：有条件通过

【当前状态】：已修复

7. 测试结论

【整体评价】：有条件通过

【统计】：高危 0 个，中危 2 个，低危 1 个，建议 3 个

【是否影响上线】：是

【遗留风险】：双扩展名绕过是中危，建议增加 MIME 类型深度检测（不仅看扩展名，看文件二进制头）。

8. 附件

附件 1：AppScan 扫描报告 (.scan 文件)

附件 2：Postman 复现脚本 (.postman_collection.json)

附件 3：相关截图 (*.png)